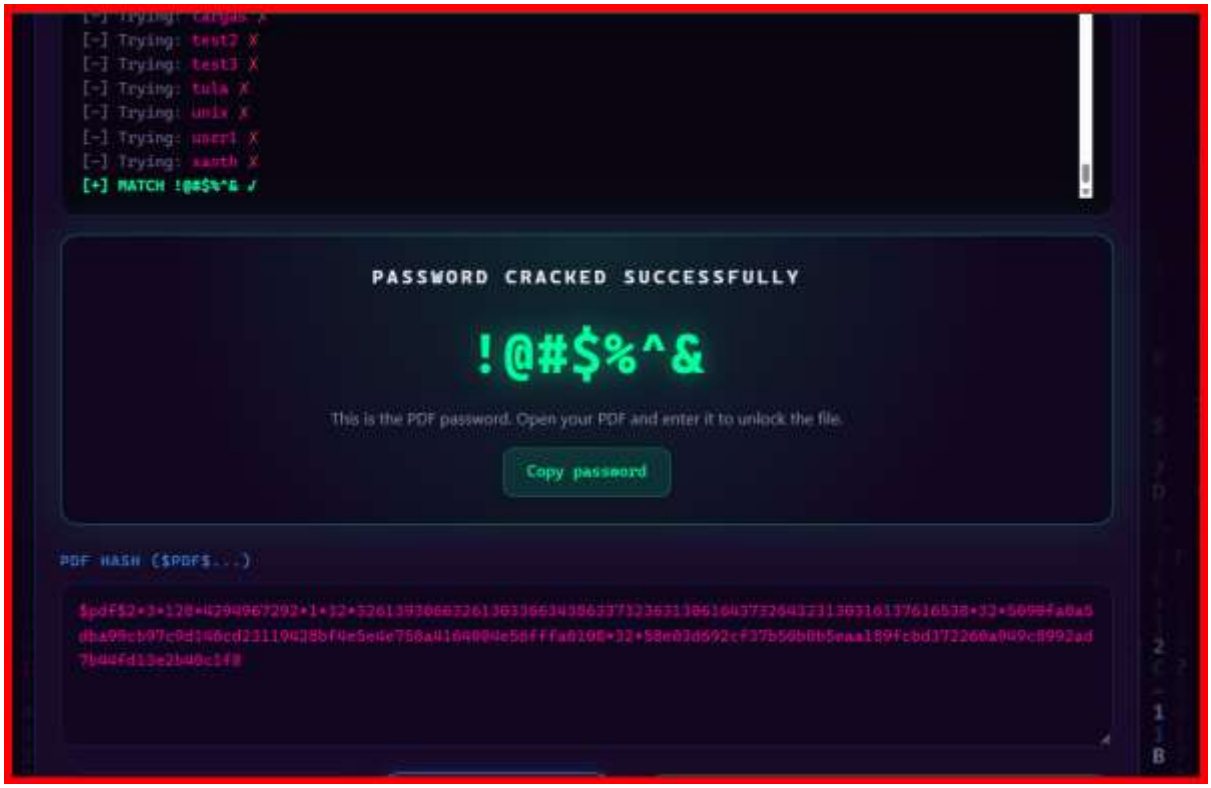
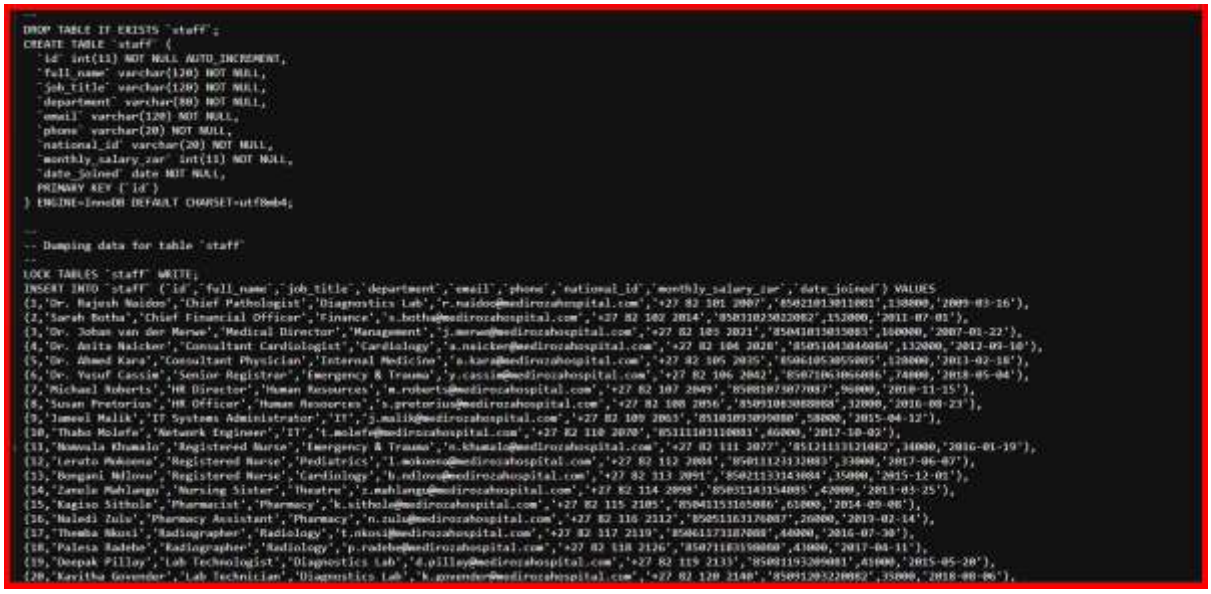

[-] Trying: test2 X
[-] Trying: test3 X
[-] Trying: tula X
[-] Trying: unix X
[-] Trying: user1 X
[-] Trying: xanth X
[+] MATCH !@#$%^& ✓
PASSWORD CRACKED SUCCESSFULLY
!@#$%^&
This is the PDF password. Open your PDF and enter it to unlock the file.
Copy password
PDF HASH (PDF...)


6,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','8505116517608?',26000,'2019-02-14'),
7,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
8,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198086',43000,'2017-04-11'),
9,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-28'),
0,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
1,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
2,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111225242084',118000,'2013-10-17'),
3,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
4,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
5,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
6,'Karen O''Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
7,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297080',27000,'2019-09-02'),
8,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
9,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
0,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
LOCK TABLES;

Table structure for table `shareholders`

OP TABLE IF EXISTS `shareholders`;
EATE TABLE `shareholders` (
`id` int(11) NOT NULL AUTO_INCREMENT,
`shareholder_name` varchar(120) NOT NULL,
`share_percent` decimal(5,2) NOT NULL,
`shares_held` int(11) NOT NULL,
`share_class` varchar(20) NOT NULL,
PRIMARY KEY (`id`)
ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

CK TABLES `shareholders` WRITE;
SERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
,'Reddy Family Trust',11.0,110000,'Ordinary'),
,'Thabo Molefe',10.0,100000,'Ordinary'),
,'Sarah Botha',9.0,90000,'Ordinary'),
,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
,'Naledi Zulu',7.0,70000,'Ordinary'),
,'Michael Roberts',6.0,60000,'Ordinary'),
0,'Dr. Vikram Chetty',4.0,40000,'Preferential');
LOCK TABLES;



```
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@mediroza
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@mediroza
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@mediroza
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@mediroza
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@mediroza
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@mediroza
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@mediroza
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@mediroza
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@mediroza
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@mediroza
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@mediroza
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@mediroza
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@mediroza
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@mediroza
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@mediroza
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@mediroza
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@mediroza
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@mediroza
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@mediroza
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@mediroza
```

#	Vulnerability	Location	Risk
1	Username enumeration on login page	`patient/login.php`	**Critical**
2	SQL injection login bypass	`patient/login.php`	**Critical**
3	Encrypted PDFs accessible after login bypass	`patient/reports/`	**High**
4	Weak PDF passwords crackable with a wordlist	`patient_report_*.pdf`	**High**
5	Sensitive metadata left in patient PDF files	`patient_report_3.pdf`	**Medium**
6	Forgotten backup folder with directory listing enabled	`old/`	**Critical**
7	Confidential staff salaries and shareholder data in plain text	`old/mediroza_db_backup_2019.sql`	**Critical**

Recommendations and Remediation

- Username enumeration: Show the same error message for a wrong username and a wrong password. Never reveal which one failed.
- SQL injection: Use parameterised queries or prepared statements. Never build SQL queries using raw user input.
- PDF access control: Store PDFs outside the web root or behind proper access controls. Use strong unique passwords per file.
- PDF metadata: Strip all metadata from patient files before distributing. Use exiftool -all= filename.pdf to clean files.
- Directory listing and backup exposure: Disable directory listing on all folders. Remove or relocate old backup files. Never store database backups in a public web folder.